Privacy and security choices

Udyam Digital · Team Aether · NIT Silchar · 7 November 2026

Scope and purpose

This competition prototype uses fictional businesses, people and identifiers. It does not verify real identities or certify legal compliance. The design applies consent, purpose limitation and data minimisation; production requirements need review before any real-customer use.

Minimum data and separate consent

Discovery asks for business type, size, locations, city tier, budget, term and service needs; contact details are not required. A separate AI notice explains external processing. KYC consent is required before document upload or specimen loading. Owners can clear the conversation, withdraw the relevant consent or reset the session.

Processing and disclosure

The selected Gemini advisor receives typed business requirements and catalogue context. Common identifiers are redacted, but arbitrary sensitive text cannot be guaranteed safe: use fictional details only. Google may use free-tier content to improve its products. KYC images and registry records are not sent to the model. On the live site, browser Tesseract extracts document text and only consented text reaches the server. The local Python version runs local OCR; GSTIN/Udyam lookups use the supplied mock CSV registries. No real government or identity API is called.

Retention and deletion

Hosted image bytes remain in the browser and OCR resources are cleared after processing. The local version deletes temporary uploads after extraction or failure. Extracted document text remains in the session until checkout, KYC-consent withdrawal, reset or session expiry. Advisor history remains until conversation clearing, AI-consent withdrawal, reset or expiry. Sessions expire after 30 minutes of inactivity. Distributed synthetic specimens and their hash-keyed OCR cache remain project assets; user uploads are not added to that cache.

Controls and verification boundaries

The live site uses HTTPS, Secure HTTP-only SameSite cookies, CSRF/origin checks and AES-GCM encrypted sessions in D1. Expiry is enforced after 30 minutes of inactivity; expired records are purged on subsequent API activity. Shared AI quotas limit public usage. Upload format, size and resolution are limited. Static file access cannot expose server files. Keys stay in a server environment or ignored owner-only local file; extracted identifiers are masked in the interface. Eligibility, quote and checkout checks run server-side. Uncertain KYC results require review; format/date/name/role checks do not prove authenticity or authority.

Before production

Add authentication and staff roles, approved KYC/e-sign providers, auditable retention and rights handling, and real serviceability/fulfilment events. Validate model quality, partner access and failure recovery. The present order tracker is a simulation, and the stated controls do not establish DPDP compliance.